

APPENDIX A: EXAMINATION PROCEDURES

Examination Objectives

Examiners should use these procedures (also referred to as the work program) intended to help them determine the quality and effectiveness of the entity's management of IT, particularly regarding development, acquisition, and maintenance-related risks as outlined in this booklet. Examiners should use these procedures to measure the adequacy of the entity's ITRM process, including management awareness and participation, risk assessment, policies, standards, and procedures, reporting, ongoing monitoring, and follow-up.

Examiners may choose to use only particular examination procedure work steps based on the size, complexity, and nature of the entity's business.

Objective 1: Determine the appropriate scope and objectives for the examination.

1. Review past reports for outstanding issues or previous problems. Consider the following:
 - a. Regulatory reports of examination.
 - b. Internal and external audit reports (e.g., SSAE18).
 - c. Internal or independent tests or reviews of controls (e.g., penetration tests, vulnerability assessments, SOC reports, business continuity reviews, and third-party management reviews).
 - d. Regulatory and audit reports on service providers.
2. Review management's response to issues raised during, or since, the last examination. Consider the following:
 - a. Adequacy and timing of corrective action.
 - b. Resolution of root causes rather than just specific issues.
 - c. Existence of any outstanding issues.
 - d. Whether management has taken positive action toward correcting exceptions reported in audit and examination reports.
 - e. Independent review of resolution and reporting of resolution to the audit committee.
3. Interview management and review responses to pre-examination information requests to identify changes to the technology infrastructure or new products and services that might increase the entity's risk. Consider the following:
 - a. Any significant strategic or business line changes, including any third-party changes.
 - b. Products or services delivered to either internal or external users.
 - c. Current network diagrams and data flow diagrams, including changes to configuration or components.
 - d. Hardware and software inventories.
 - e. Loss or addition of key personnel.
 - f. Inventories of third-party providers and software vendors, including services provided.

- g. Organizational charts that include reporting relationships between business units and control functions (e.g., enterprise risk management, ITRM, and internal audit).
- h. Credit or operating losses primarily attributable (or thought to be attributable) to IT (e.g., system problems, inadequate controls, improperly implemented changes to systems, and fraud resulting from cybersecurity attacks, such as account takeover).
- i. Changes to internal business processes.
- j. Internal reorganizations.

Objective 2: *Management establishes, and the board of directors (board) oversees, an effective governance structure that includes development, acquisition, and maintenance activities. Additionally, the board oversees related IT project management processes used to manage projects related to those activities. (Section II, [“Governance of Development, Acquisition, and Maintenance”](#))*

Review the following documents to understand the overall structure and hierarchy of management and oversight activities related to development, acquisition, and maintenance:

- Enterprise-wide IT policies, procedures, and standards describing the entity’s requirements throughout the development, acquisition, and maintenance life cycle.
 - Charters (e.g., board, management, or committee), organizational charts, relevant documentation, and practices to determine whether appropriate roles and responsibilities are identified and assigned with suitable decision-making authority.
 - Project plans and meeting minutes of the board and committees to ensure that activities and projects align with the entity’s strategic objectives and the board’s risk appetite.
 - Project audit reports to determine whether the audit function provides independent, objective assurance of the effectiveness of an entity’s development, acquisition, and maintenance activities.
 - Documentation of controls for personnel with access to program code to limit placement into the production environment.
 - QA reports to evaluate processes for the detection of potential coding errors.
1. Determine whether the board and senior management provides for the following:
 - a. An effective governance structure that allows for the effective oversight and management of the development, acquisition, and maintenance of the entity’s systems and components.
 - b. Oversight of development, acquisition, and maintenance IT project management processes and projects related to those activities.
 - c. Oversight of significant projects to ensure that they align with an entity’s strategic plans.
 - d. Consideration of business strategies and objectives, resilience needs, information security requirements, legal and regulatory requirements, and allocation of resources (e.g., personnel, budget, and time) when evaluating IT projects and activities.
 - e. Consideration of the needs of internal and external stakeholders when making decisions regarding IT development, acquisition, and maintenance activities.

- f. Establishment of audit's role in reviewing development, acquisition, and maintenance activities, and ability to raise objections if they believe the control environment is inadequate.
2. Determine whether the board and senior management develops and implements comprehensive, entity-wide IT policies, procedures, and standards addressing entity requirements throughout the development, acquisition, and maintenance life cycle. Does the board, senior management, and designated committees of the board perform the following:
 - a. Regularly review and approve IT policies and standards.
 - b. Review and approve procedures to meet changing IT policies and standards.
 - c. Provide for policies that clearly delineate development, acquisition, and maintenance responsibilities and provide for communication to all personnel, stakeholders, and appropriate third parties.
 - d. Review and approve deviations from policies, standards, and procedures related to development, acquisition, and maintenance.
 - e. Identify and assign appropriate roles and responsibilities for the entity's development, acquisition, and maintenance activities.
 - f. Identify and address training needs to support development, acquisition, and maintenance responsibilities.
 - g. Provide for an escalation process for development, acquisition, and maintenance issues.
3. Determine whether the board and senior management identified and provided for key management responsibilities related to development, acquisition, and maintenance activities. Examples of key roles which carry those responsibilities include the following:
 - a. Board and senior management.
 - b. CIO.
 - c. CISO.
 - d. IT steering committee.
 - e. Business line management.
4. Determine whether management identified and provided for the responsibilities of IT project management related to development, acquisition, and maintenance activities. Examples of key project management roles that carry those responsibilities include the following:
 - a. Sponsor.
 - b. Project owners.
 - c. Product owner.
 - d. Project or program manager.
 - e. Business change manager.
 - f. Program management office or organization personnel.
 - g. Stakeholders.

5. Determine whether management identified and provided for the responsibilities of key roles in development activities. Examples of key development roles that carry those responsibilities include the following:
 - a. Network architects.
 - b. Developers.
 - c. Software engineers.
 - d. Hardware engineers.
 - e. Information security analysts.
 - f. Systems analysts.
6. Determine whether management identified and provided for the responsibilities of key roles in acquisition activities, including examples such as procurement manager or third-party risk manager.
7. Determine whether maintenance personnel provide for appropriate maintenance throughout the life cycle of systems and components. Determine whether maintenance personnel
 - a. Have knowledge and understanding of all relevant systems and components they are expected to operate and maintain.
 - b. Analyze and understand the costs of maintenance (e.g., budget, time, or personnel) versus the costs of not performing maintenance (e.g., system failures, data breaches, and customer dissatisfaction).
 - c. Track the analysis of costs for reporting to management.
 - d. Maintain independence from development roles to prevent developers from accessing production environments.
8. Evaluate audit's role in reviewing development, acquisition, and maintenance activities. Consider the following audit activities:
 - a. Validating that sufficient time is built into project schedules to define controls and verify that all appropriate stakeholders are involved.
 - b. Determining the effectiveness of controls necessary in the entity's development, acquisition, and maintenance activities and recommending appropriate mitigation.
 - c. Guiding developers in considering appropriate control standards and frameworks throughout IT projects.
 - d. Reviewing the internal controls, testing, and audit trails included in systems and components during each SDLC phase.
 - e. Performing post-implementation reviews shortly after implementation of new or revised systems or components.

Objective 3: *Evaluate whether management implements continuous risk management processes within the entity's development, acquisition, and maintenance activities to identify reasonably foreseeable internal and external risks and threats, including those that could result in unauthorized disclosure, misuse, alteration, or destruction of customer information*

or customer information systems. (Section III, “[Risk Management of Development, Acquisition, and Maintenance](#)”)

1. Examiners should review management’s continuous risk management processes for development, acquisition, and maintenance. Consider the following:
 - a. Policies, standards, and procedures for identifying, measuring, mitigating, monitoring, and reporting risks related to development, acquisition, and maintenance activities.
 - b. Documented processes and metrics used to measure the level of risk.
 - c. Detailed documentation of processes used to review, accept, and document risks that management cannot mitigate or transfer.
 - d. Documentation of risk assessment processes to identify key risks at the onset of IT projects and throughout their life cycles.
 - e. Risk assessments that highlight internal and external risks related to development, acquisition, and maintenance activities.
 - f. Documentation of ongoing processes and reports to monitor and communicate risk, including emerging risks related to development, acquisition, and maintenance activities.
 - g. Reports to stakeholders that are timely, accurate, and include clear, relevant metrics.
2. Evaluate whether management has identified reasonably foreseeable internal and external risks and threats, including those that could result in unauthorized disclosure, misuse, alteration, or destruction of customer information or customer information systems. Consider management’s risk management actions in addressing the following:
 - a. Risks that could result in a severe disruption or material compromise to critical service delivery.
 - b. Policies, standards, and procedures for identifying, measuring, mitigating, monitoring, and reporting risks related to development, acquisition, and maintenance activities.
 - c. Repeatable process adoption, to ensure that risks are consistently addressed across the entity over time.
 - d. Risk identification and assessments involving stakeholders with business process knowledge who may be affected by the development, acquisition, or maintenance activities or the related IT projects.
 - e. Threat model usage commensurate with the overall threats to the entity, to assess appropriateness of security policies, standards, and procedures.
 - f. Process to review, accept, and document risk when management cannot mitigate or transfer risk, and its acceptance by the board.
 - g. Regular review and approval of risk acceptance decisions consistent with the entity’s governance structure.
 - h. Information security concerns.

3. Determine whether management has established effective risk measurement, monitoring, and reporting processes, including for emerging risks. Consider the following:
 - a. Implementation of effective standards to measure risk in the entity's development, acquisition, and maintenance activities.
 - b. Establishment of an ongoing risk measurement process, commensurate with the size and complexity of the entity's activities.
 - c. Communication of technical aspects through reports to the board that are clear and understandable to board members (e.g., explaining acronyms or technical jargon) and that relate IT issues to business concerns.
 - d. Receipt of reports on IT project risks, such as critical projects that may miss key milestone dates, identification of negative test results, or changes to business or technical requirements.

Objective 4: *Evaluate whether management has implemented effective risk mitigation throughout development, acquisition, and maintenance activities regardless of the phase of the project in the life cycle and agnostic as to the type of technology. Specific risks and controls should be considered depending on management's chosen solution. (Section IV, "[Common Development, Acquisition, and Maintenance Risk Topics](#)")*

For this objective, examiners should review and assess the following:

- Systems, components, and services, including related contracts and licenses, throughout the supply chain for appropriate risk identification and mitigation.
- Secure coding standards, configurations, and security controls used to harden each system or component, data, and activity logs for appropriate processes and implementation and maintenance of confidentiality, integrity, and availability.
- Inventory of all systems, components (e.g., open-source, proprietary, APIs, and container images and registries), including related licenses, and data as part of ITAM.
- Processes for access controls, authorization, and authentication for systems and components, data, and related documentation throughout the supply chain to ensure appropriate security.
- Roles and responsibilities to evaluate segregation of duties in and ongoing management commitment to development, acquisition, and maintenance activities.
- Process of selecting and implementing methodologies to enable effective management and control of development, acquisition, or maintenance projects and alignment with entity objectives.
- Operating parameters (e.g., timing, speed, throughput, and data validation) for systems and components to determine performance.
- Activity logs related to systems, components, and data to identify operating risks.
- Monitoring processes of development and maintenance activity for identification of anomalies and unauthorized access or modification to systems, components, and data.
- Reporting processes for decision-making and measuring the level of project success.
- Training on development, acquisition, and maintenance concepts (e.g., methodologies); effectiveness of training; and capability of personnel to implement concepts learned.
- Documentation of internally developed programs and externally procured products and services to effectively operate and maintain the systems and components.

- Evaluation process (e.g., post-implementation review, stakeholder interview, problem documentation and resolution, cost-benefit analysis, and reports to senior management) for development, acquisition, and maintenance projects.
1. Evaluate management's oversight of use of open-source and COTS components. Consider the following:
 - a. Identification and mitigation of risks related to the use of open-source components.
 - b. Evaluation of documentation providing support if there are open-source components supporting any line of business.
 - c. Proactive maintenance of updated application and user documentation, especially when code changes are made.
 - d. Consultation with third-party providers and vendors regarding recommended security controls to harden the COTS solution.
 - e. Mitigation of risks related to integration (e.g., lack of interoperability or integration between systems and components).
 2. Evaluate management's ability to negotiate, administer, and implement practices regarding licenses, agreements, and copyright protection. Consider whether management
 - a. Accurately assesses current and future needs and ensures that licenses continue to meet the entity's needs.
 - b. Reviews licenses, obtaining confirmation that they clearly state whether system or component usage is exclusive, the number of user licenses, and whether there are any time, place, manner, or other types of limitations with the system or component's use.
 - c. Specifies in its agreements the appropriate time periods for all licenses and the minimum amount of notice required for license termination.
 - d. Periodically reviews system and component licenses to compare all installed licensed systems and components with the respective license terms.
 - e. Determines whether a third-party vendor provides access to source or object code ("code") when drafting agreements.
 - f. Reviews licenses to determine whether they include retention and use of backup copies of any mission-critical system or component on which the entity may rely for disaster recovery or business continuity purposes at remote sites.
 - g. Negotiates, when possible, with licensors to ensure the inclusion of retention and use of backup copies if they are omitted from the terms of a license.
 - h. Understands any resulting limitations and consequent risks if involved in difficult license agreement negotiations, including when an entity has limited negotiating power.
 - i. Periodically reviews system and component licenses to compare all installed licensed systems and components with the respective license terms.
 - j. Considers what is stated in the licenses; costs of obtaining them; and risks, fines, and other compliance liabilities for violating their provisions or requirements.
 - k. Includes related entities (e.g., subsidiaries or contractors) as users in their licenses when the entity plans to provide the systems or components to them.

- l. Implements appropriate licenses for the systems or components developed when management is responsible for developing systems and components and providing them to other entities or its subsidiaries.
 - m. Maintains awareness of the liabilities that come with licensing activities, including considerations related to hardware maintenance, integration, compatibility, and fraud, when the entity builds hardware and licenses that hardware to other entities.
 - n. Specifies in its agreements the appropriate time periods for all licenses and the minimum amount of notice required for license termination.
 - o. Addresses inappropriate usage if there is a discrepancy between actual usage and the total number of installed licenses allowed by the agreement.
 - p. Addresses maintenance agreements, which outline available maintenance services (e.g., provision of new versions, releases, or updates).
 - q. Obtains appropriate vendor permission and participation for modifications to the code for systems and components.
 - r. Ensures that the agreement addresses and prompts updates to application and user documentation when any changes are made to procured systems or components.
3. Assess whether management's ITAM program includes oversight and management of the software and hardware licenses for components used by the entity. Consider management
 - a. Awareness of the liabilities that come with licensing activities, including considerations related to software maintenance, integration, compatibility, and fraud if an entity develops software and licenses that software to others.
 - b. Maintenance of an accurate inventory of FOSS as part of an effective ITAM process and understanding of and abiding by the requirements of FOSS licenses.
 - c. Awareness of what information is shared when contributing in return to the FOSS development community.
 - d. Maintenance of program provisions for identification and management of any hardware licenses.
4. Evaluate management's oversight of copyright protections. Consider management's actions
 - a. When deploying procured systems or components for use in the entity's infrastructure, including physical and virtual networks.
 - b. When reviewing and approving the procurement and use of systems or components in the entity's IT environment to ensure appropriate use.
5. Assess management's actions to promote secure development practices for products and services developed and used. Consider management's actions to
 - a. Monitor third parties' activities to enforce conformance with the entity's contract requirements, Information Security Standards, and legal and regulatory requirements when management outsources development to third parties.
 - b. Evaluate or have a method to evaluate the third party's secure coding standards (e.g., through independent certification or audit) when acquiring systems and components.

- c. Determine that secure development standards apply to the development of any system or component changes (e.g., patches or updates) for the maintenance of systems and components.
 - d. Incorporate security in the code, and implement quality management, which is critical to the secure development process.
 - e. Determine that the embedded rules of the code review tools are appropriately configured and used if an automated code review process is implemented.
 - f. Maintain a secure operating environment throughout development, acquisition, and maintenance activities, promoting secure development practices whether operations are performed in-house by entity personnel or outsourced to a third party.
6. Assess management's actions to securely manage data. Consider management's actions to
 - a. Identify the data, their characteristics (e.g., customer sensitive information or proprietary information), and sensitivity (e.g., confidential, internal use only, or public).
 - b. Document the data in an inventory that includes locations and uses of data in development, acquisition, and maintenance activities and in IT projects.
 - c. Include data security in development, acquisition, and maintenance activities.
 - d. Provide appropriate data confidentiality, integrity, availability, and resilience procedures for data input and output, including the use of data in IT projects.
7. Assess management of microservices activities related to development, acquisition, and maintenance. Consider the following management actions:
 - a. Setting parameters for the processes of registration to and deregistration from the service registry.
 - b. Implementation options that meet the entity's security requirements.
 - c. Implementation and management of microservices-based architectures, including monitoring of the many services, which may be running on different servers or written in different languages.
 - d. Consideration of the following monitoring controls:
 - Monitoring at the gateway and service level.
 - Implementing a centralized dashboard to display the status of multiple services and network segments.
 - Creating a baseline and implementing intrusion detection to provide alerts on deviations from the baseline.
8. Assess management's consideration of risk in the use of containers, such as image risk, registry risk, orchestrator risk, container risk, and host OS risk, and effective countermeasures to risk. Consider management actions to address data isolation when setting up containers.

9. Evaluate management's risk mitigation strategies for API activities. Consider the following:
 - a. Configuration of the API with the necessary infrastructure services.
 - b. Application of extra layers of security beyond those for standard end-point security, and implementation of appropriate authorization checks at the object level.
 - c. Implementation of appropriate security, patches, updates for APIs, and disabling of unnecessary functions.
 - d. Appropriate setting of all API processing parameters (e.g., execution timeouts, maximum allocatable memory, number of file descriptors, number of processes, request size, number of requests per client or resource, and number of records per page to return in a single request response).
 - e. Verification that all access is denied by default and employ specific role-based permissions for users to gain access to functions.
 - f. Denial of access to properties unnecessary for the user's role, and access only allowed when necessary.
 - g. Validation and filtering of all data coming to an API with appropriate parameters.
 - h. Maintenance of logging of API activity (e.g., authentication, errors, redirects, rate limiting, and end points, including their parameters, requests, and responses).
 - i. Implementation of continuous logging and monitoring of relevant API activity (e.g., failed authentication attempts, denied access, and input validation errors).
 - j. Maintenance of secure logs and ensuring only appropriate access to them to maintain confidentiality and integrity of sensitive data in activity logs.
10. Assess management's implementation and use of any methodologies for project management. Consider management actions
 - a. Establishing appropriate methodologies to enable effective management and control of system and component development, acquisition, and maintenance activities.
 - b. Aligning implementation of any methodology with the overall strategic and business objectives.
 - c. Promoting effective planning through IT project management and support training for developers, quality management members, testers, and maintenance personnel.
 - d. Considering the risk of not following established control procedures when using prototyping models.
 - e. Considering security development process weaknesses when using agile methodologies and determining appropriate mitigation strategies.
11. Evaluate quality management actions. Consider
 - a. Implementation of compensating controls when they cannot fully achieve segregation of duties between quality management and development roles.
 - b. Provision of adequate support for projects throughout an entity to promote success of a project.